

Nothing is Safe: An Introduction to Hardware (In)Security

Nathan Jones

Mindstorms Engineering, LLC
Embedded Systems Design & Education

[mindstormsengineering.github.io](https://github.com/mindstormsengineering)



Every device needs hardware security.

(Ref01)

→ Who would want to get their hands on my device?
→ What could they do if they did?

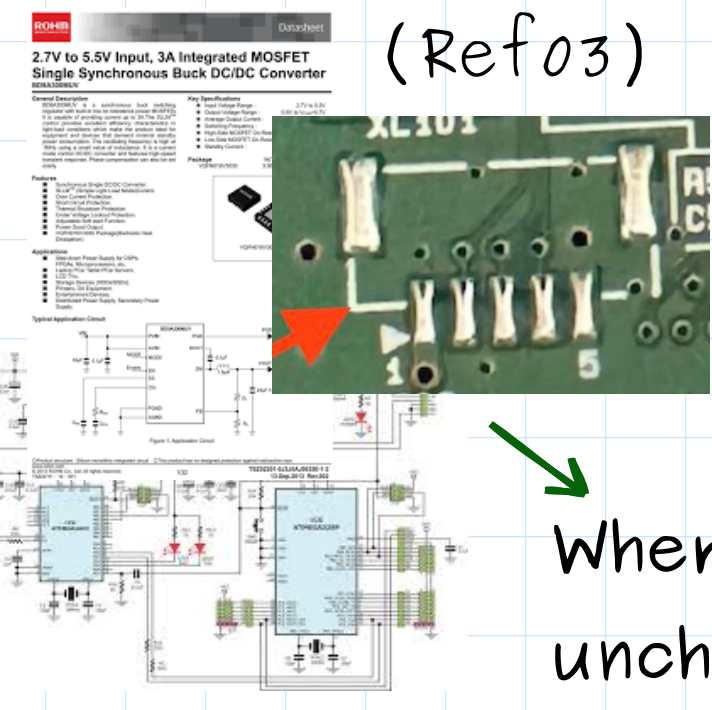


(Ref02)

Learning objectives

- Describe the vulnerabilities an attacker looks for
- Describe attacks such as brute force, replay, fuzzing, man-in-the-middle, simple/differential power analysis, and fault injection
- Explain why knowledge of these attacks matters

- Product manuals
- Schematics, FW
- Repair tutorials
- Patent filings
- FCC filings
- Datasheets
- (Un)Labelled ports

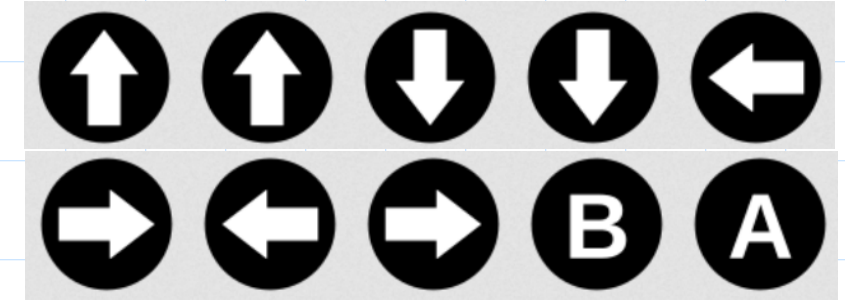


(Ref03)

Where are there unchecked assumptions?

Level 1: Research

Undocumented modes



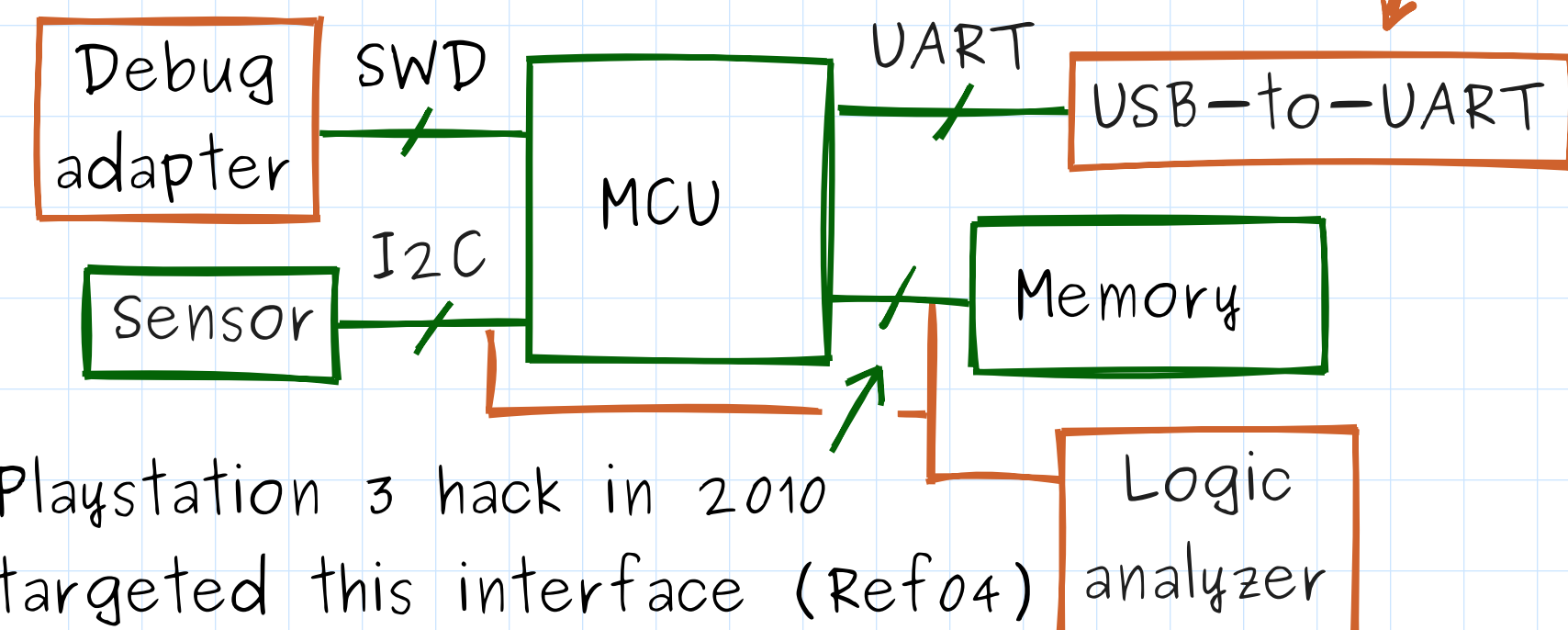
Replay attack

```
-- Msg1 --> MCU
-- "Msg1" --> MCU
```

Brute force

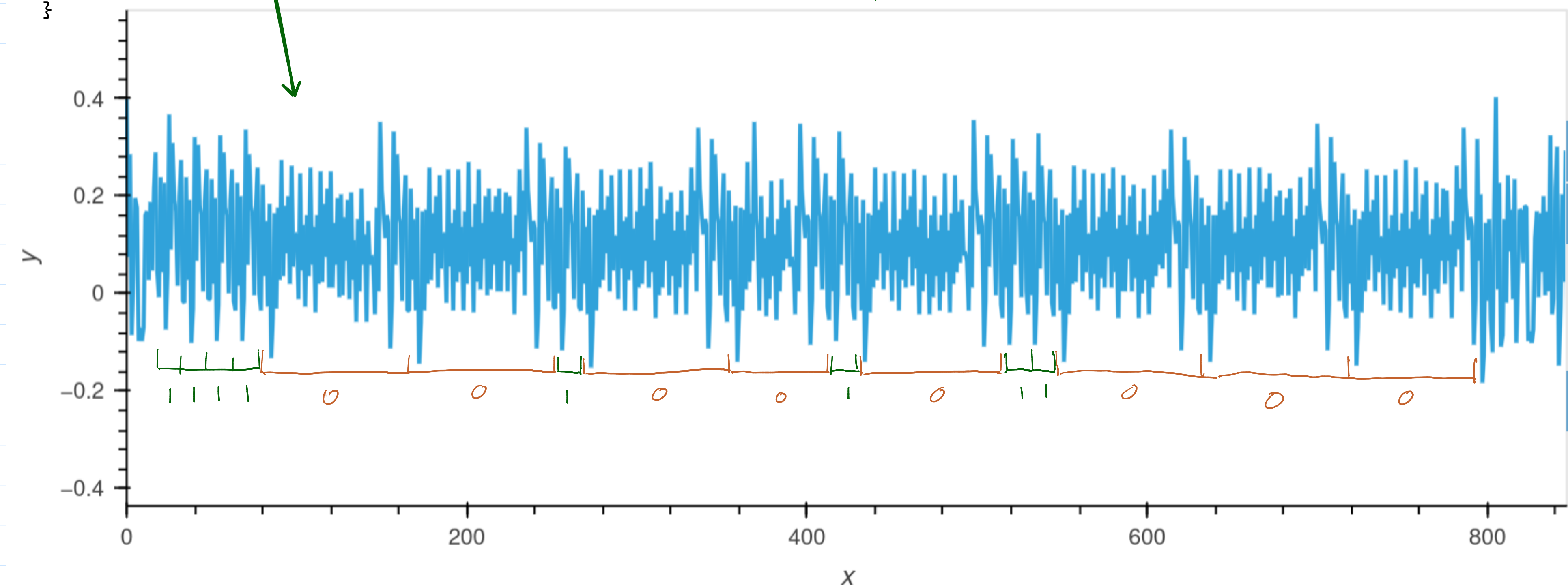
```
Enter pw: 000000
Incorrect
Enter pw: 000001
Incorrect
...
Fuzzing
Enter pw: ^wy}@$-pL8 (resets)
Enter pw: N-1CK@u'^8]
Welcome, admin!
```

Level 2: Passive observation/Logical attacks

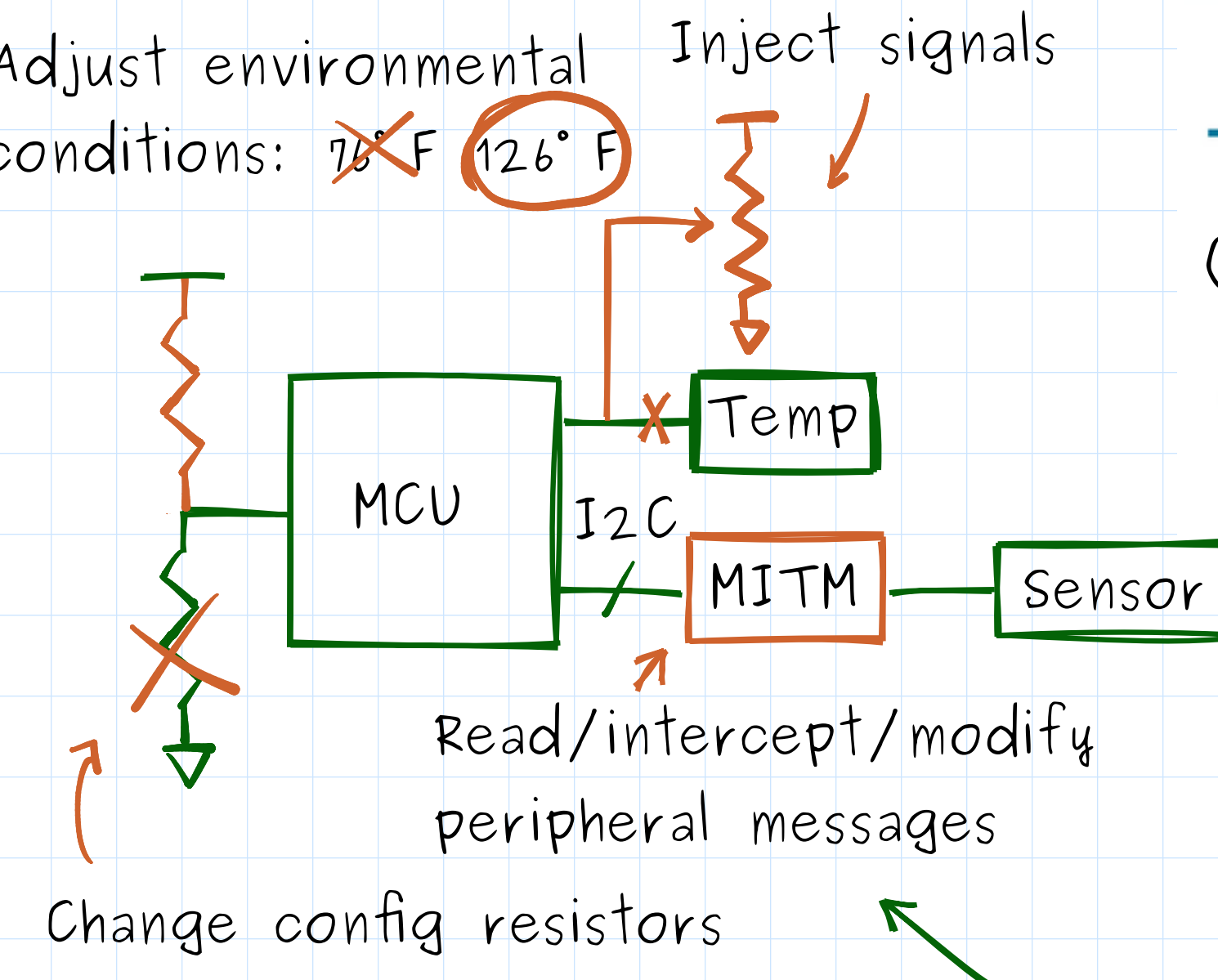


Playstation 3 hack in 2010 targeted this interface (Ref04)

```
uint16_t key = 0x1a4f;
for(size_t idx = 0; idx < 16; idx++)
{
    if(key & (1<<idx)) pt[idx] = pt[idx]*2;
    else pt[idx] = pt[idx]/3;
}
```

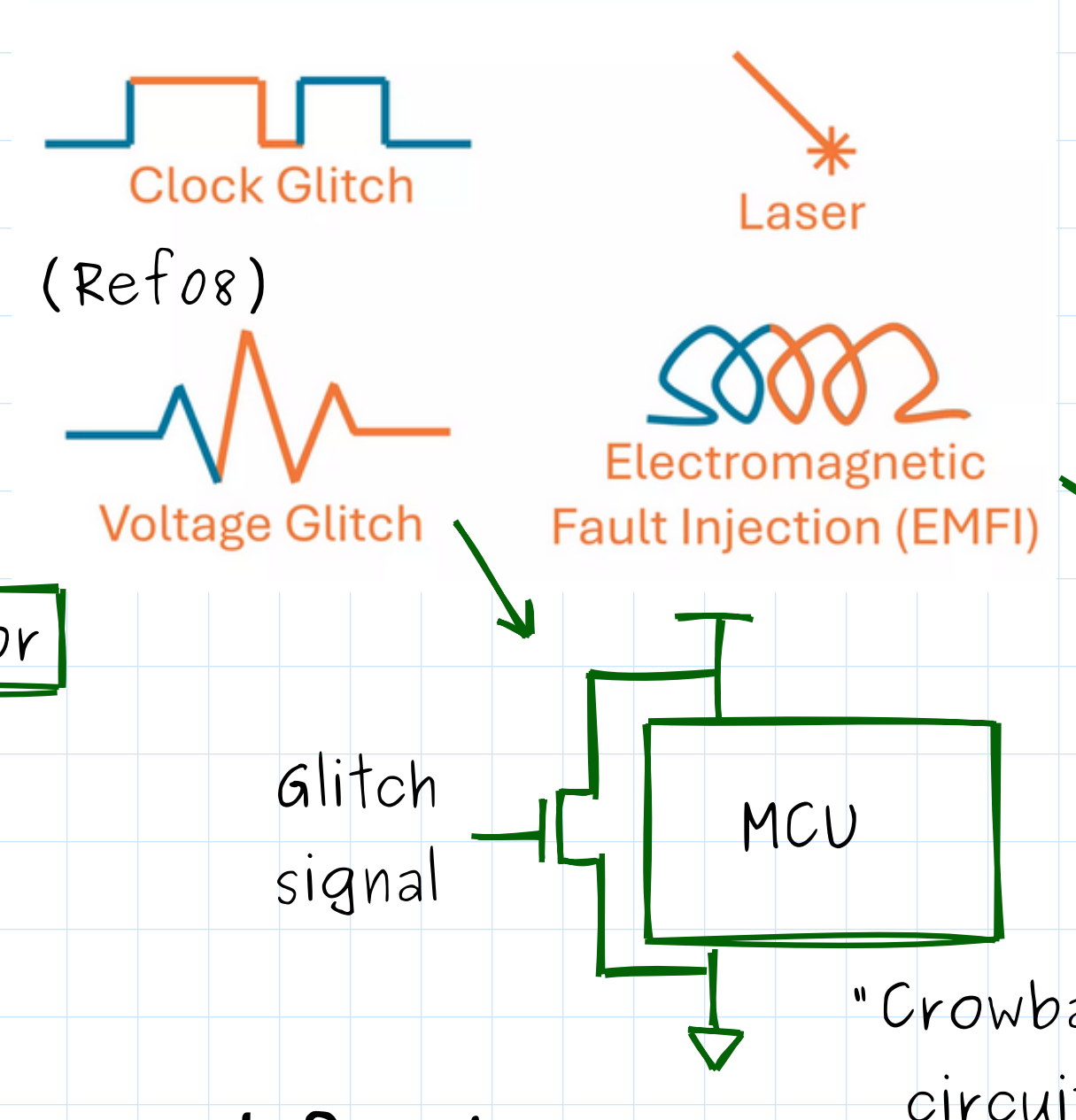


Adjust environmental conditions: ~~70°F~~ 126°F



Level 3: Physical modifications

Fault Injection Attacks

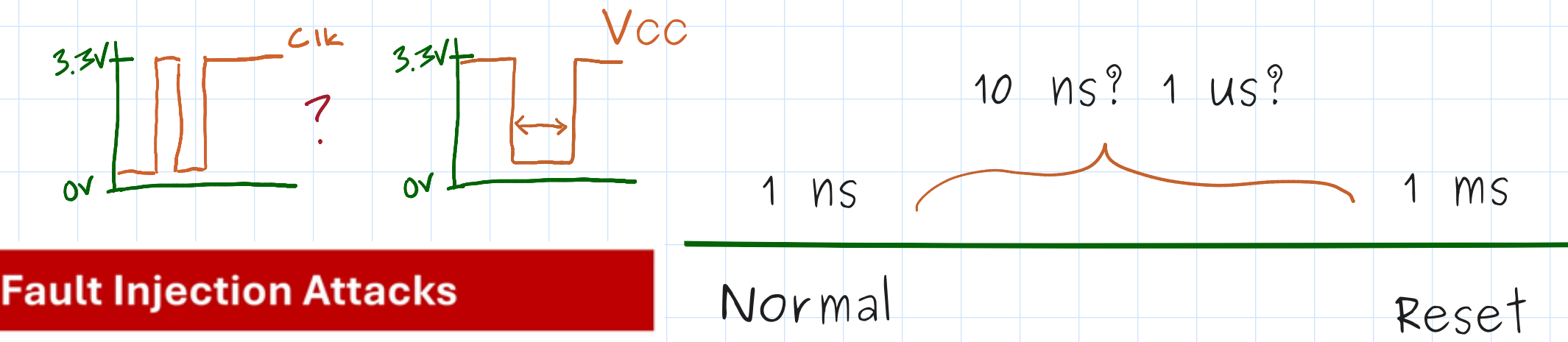


Every MCU has required operating conditions...

(Ref09)

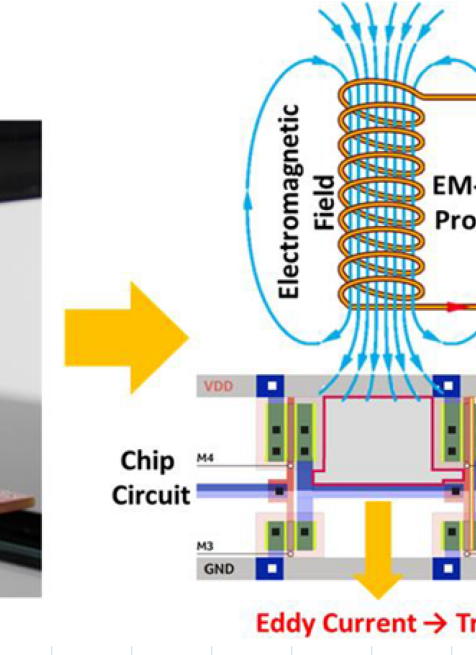
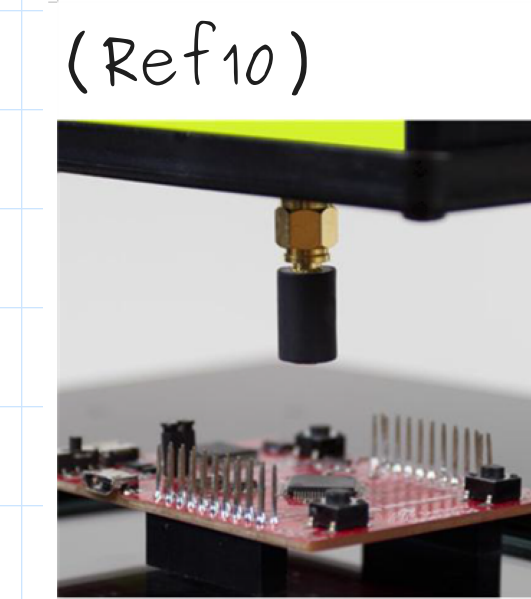
Symbol	Parameter	Min	Max	Unit
f _{HCLK}	Internal AHB clock frequency	0	48	MHz
f _{PCLK}	Internal APB clock frequency	0	48	
V _{DD}	Standard operating voltage	2.0	3.6	V

But what would happen if those conditions weren't met?

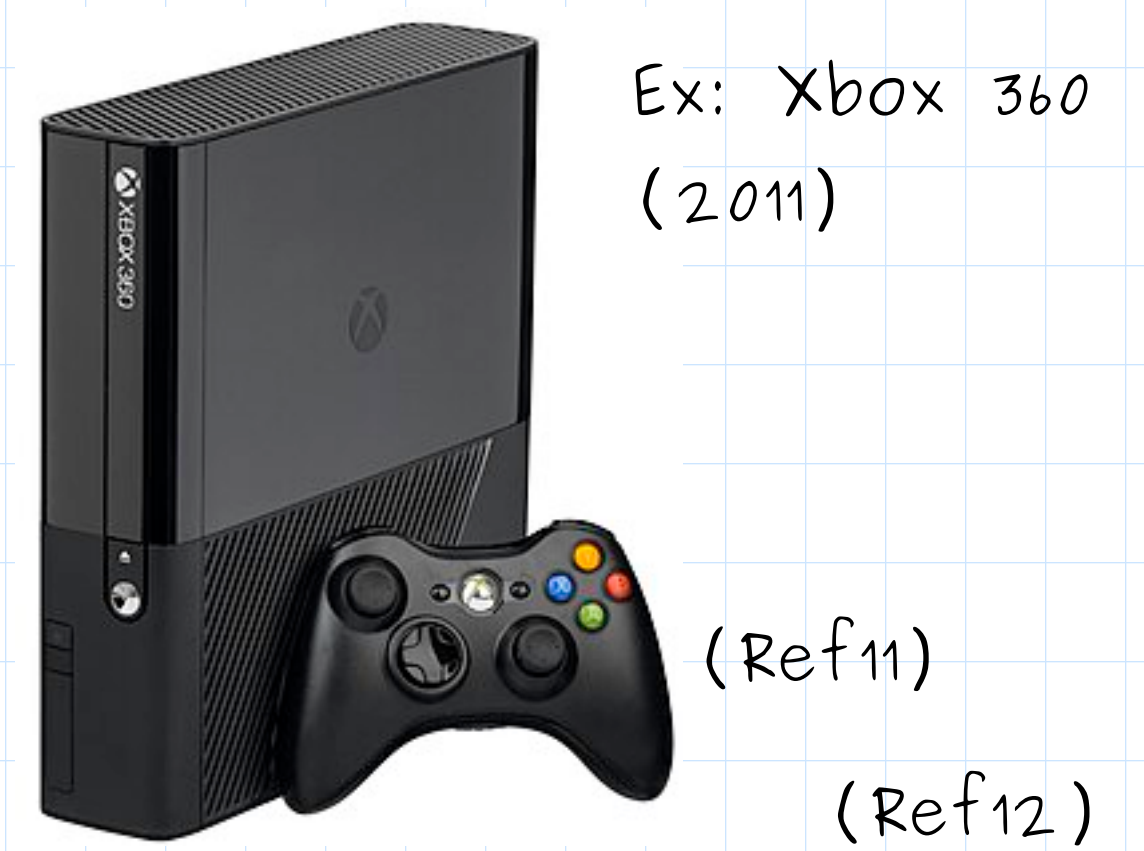
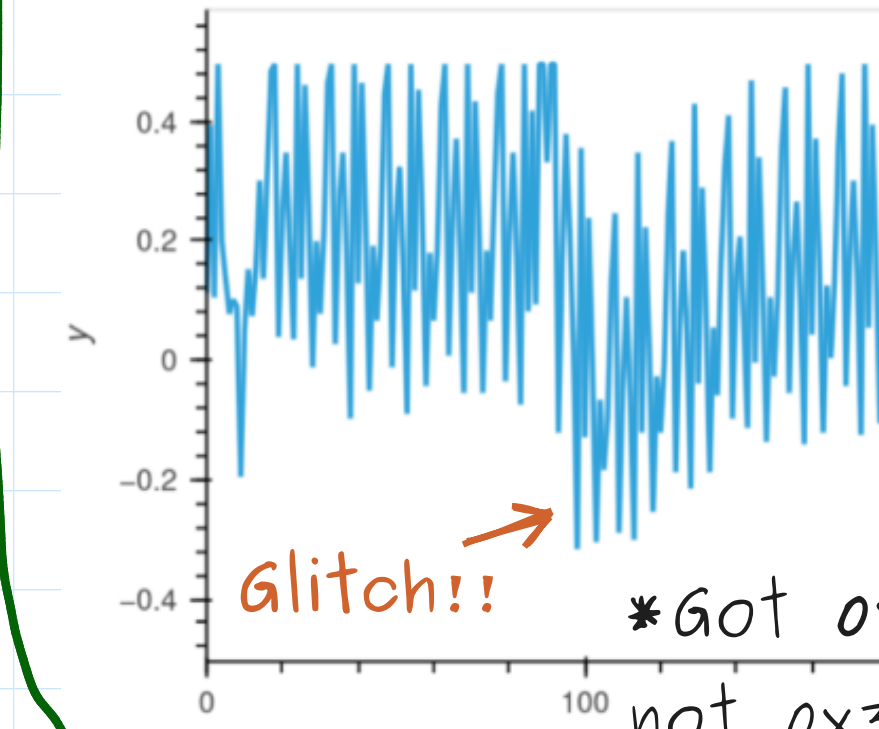
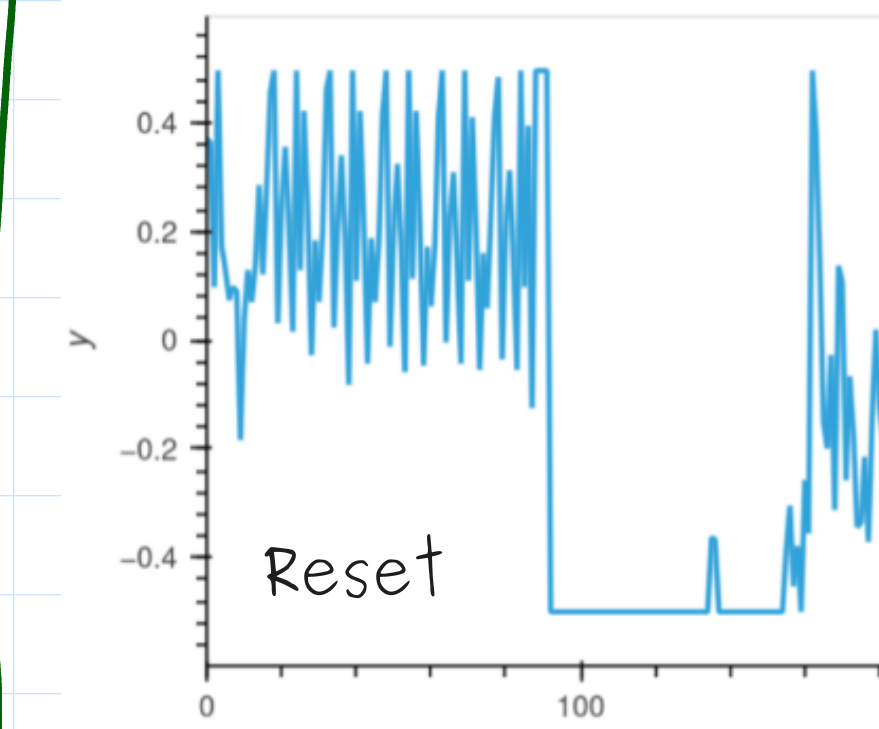
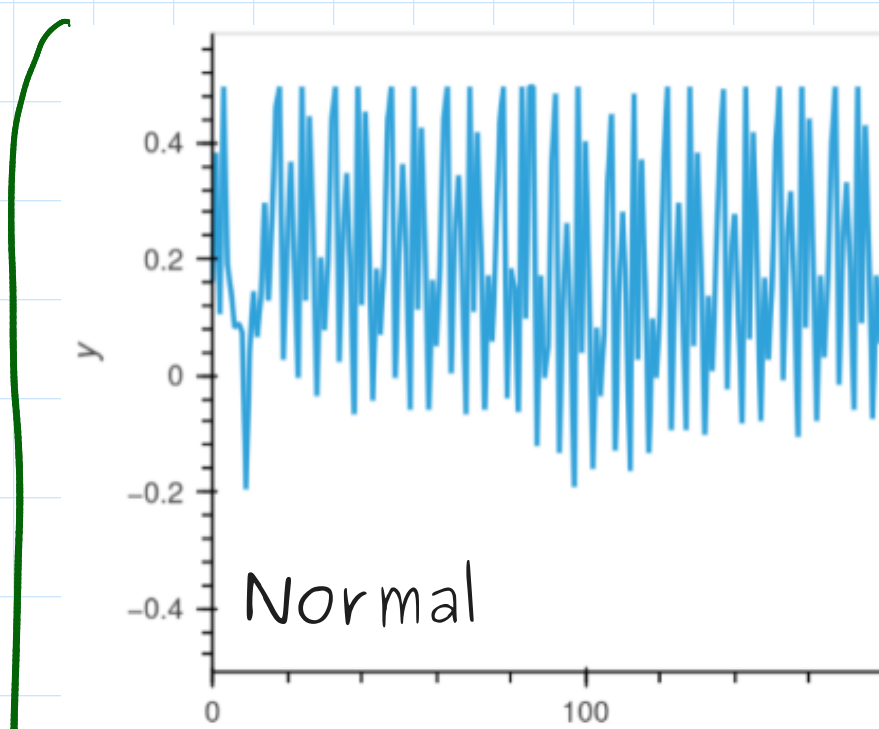


We don't know! But possibly:

- Skipped instructions
- Altered/corrupted instructions
- Altered/corrupted memory



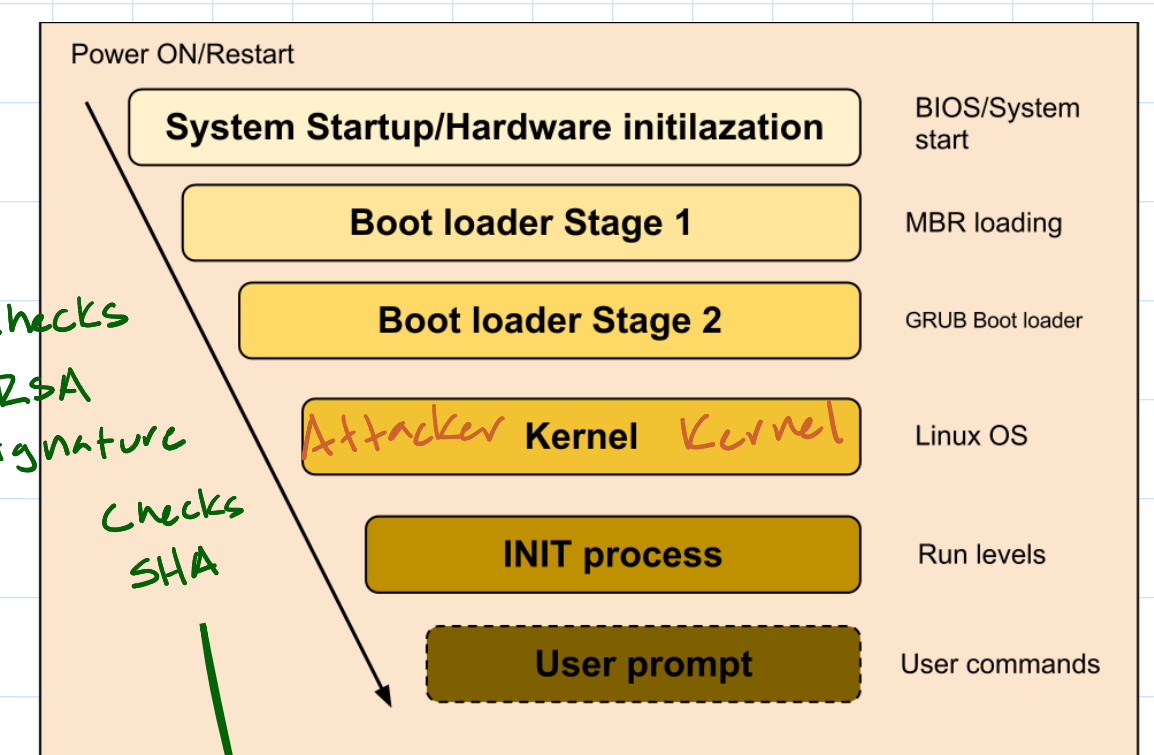
Level 5: Fault injection attacks



Ex: Xbox 360 (2011)

(Ref11)

(Ref12)



```
// Overly simplified Xbox code
if(memcmp(ker_sha, exp_sha, n) == 0)
{
    run_kernel();
}
else error();
```

Glitch this!!

Discuss! How would you fix this code?

Level 4: Side-channel attacks

```
char * correctPw = "123456";
if(strcmp(enteredPw, correctPw) == 0)
{
    printf("Access granted! :) \n");
}
else printf("Access denied :( \n");
```

Discuss! How would you fix this code?

Ex: Vantec NexStar HDD



(Ref06)

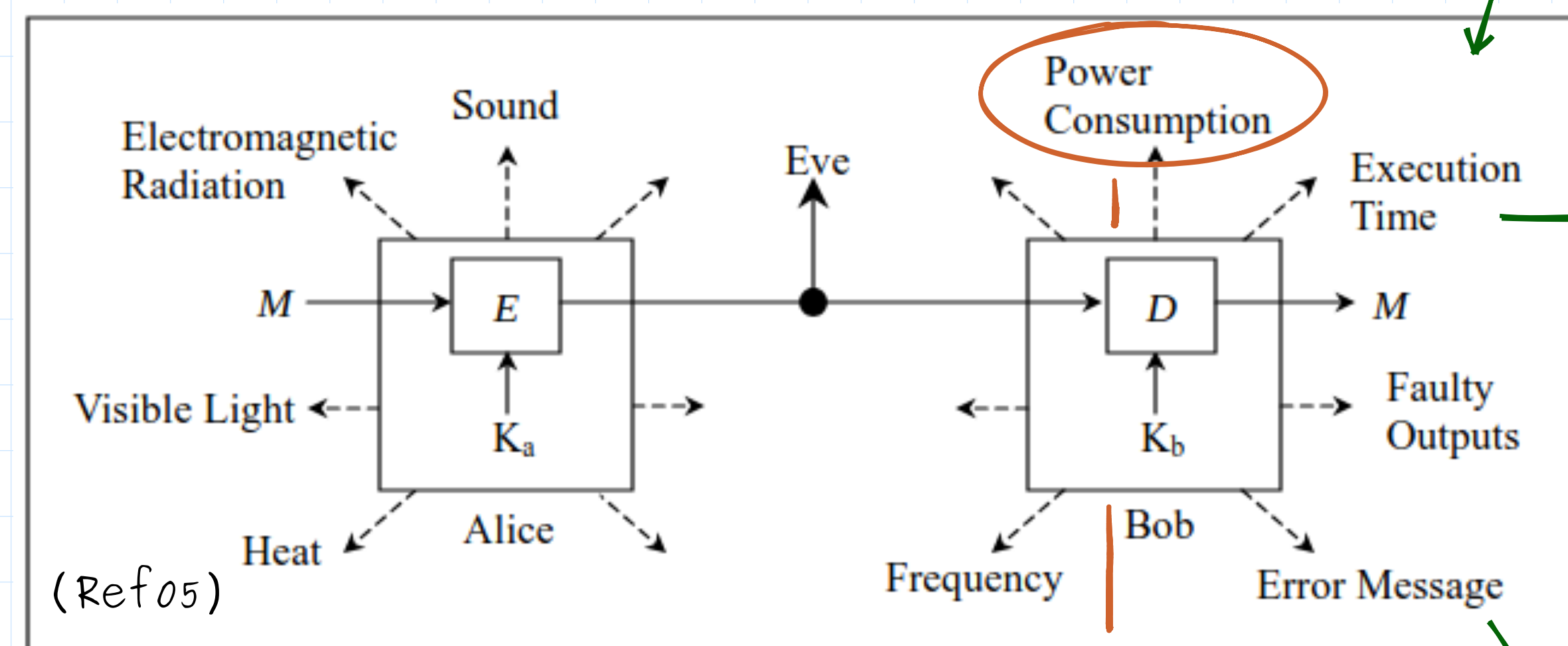
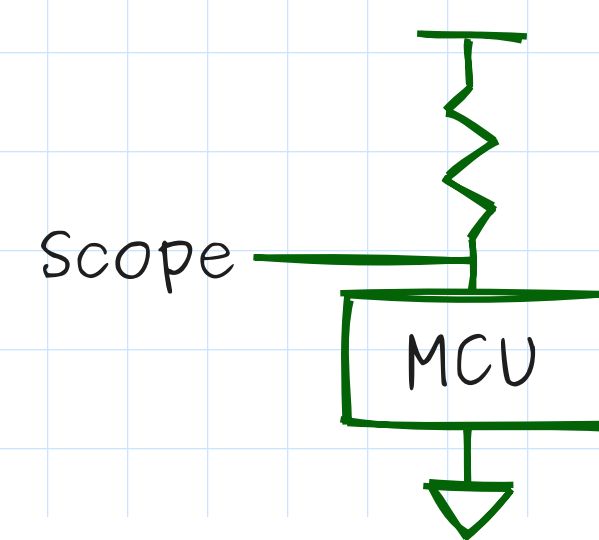


Figure 2: The cryptographic model including side-channel

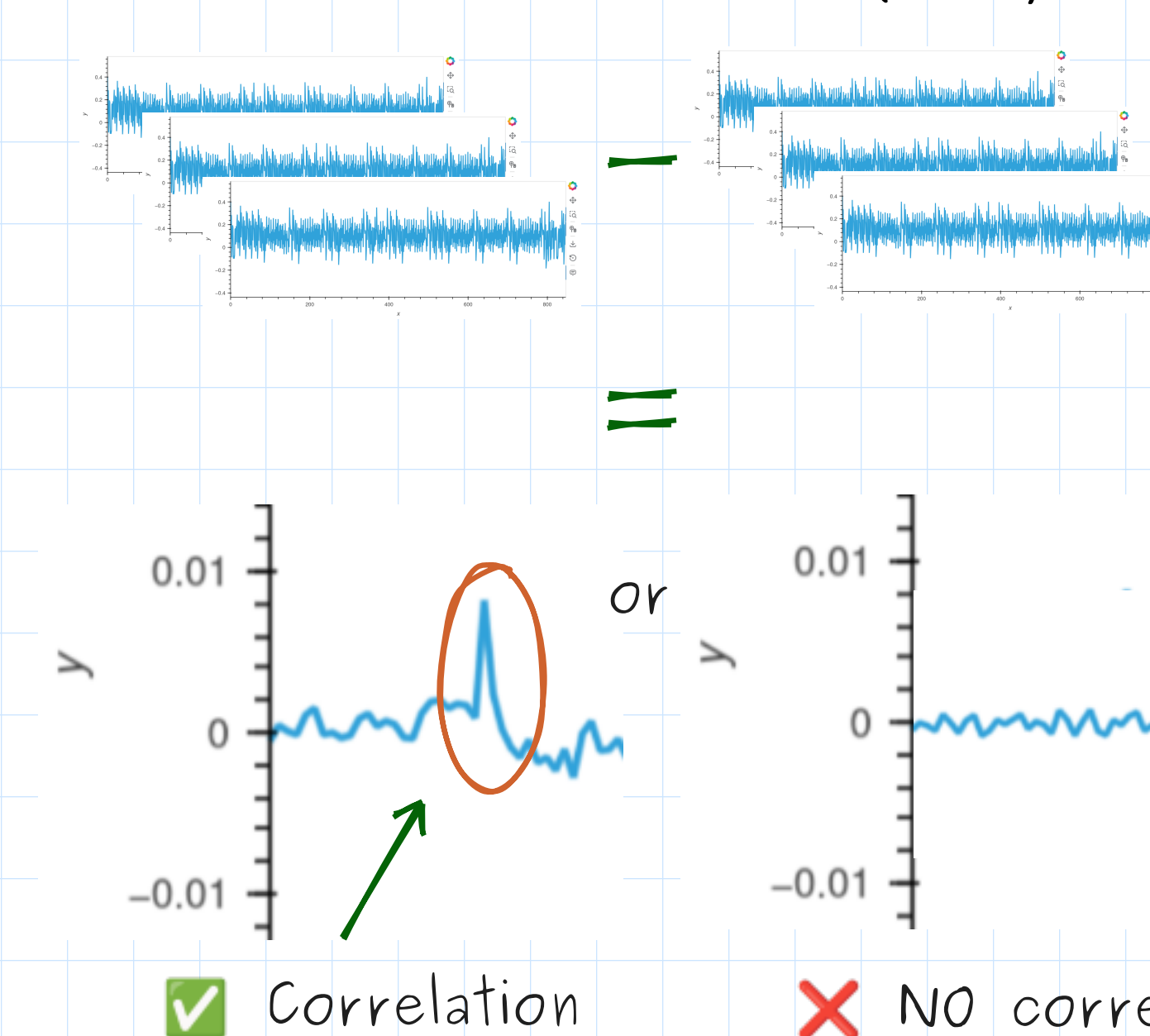
"Incorrect password for this user name"

Simple Power Analysis



Differential Power Analysis

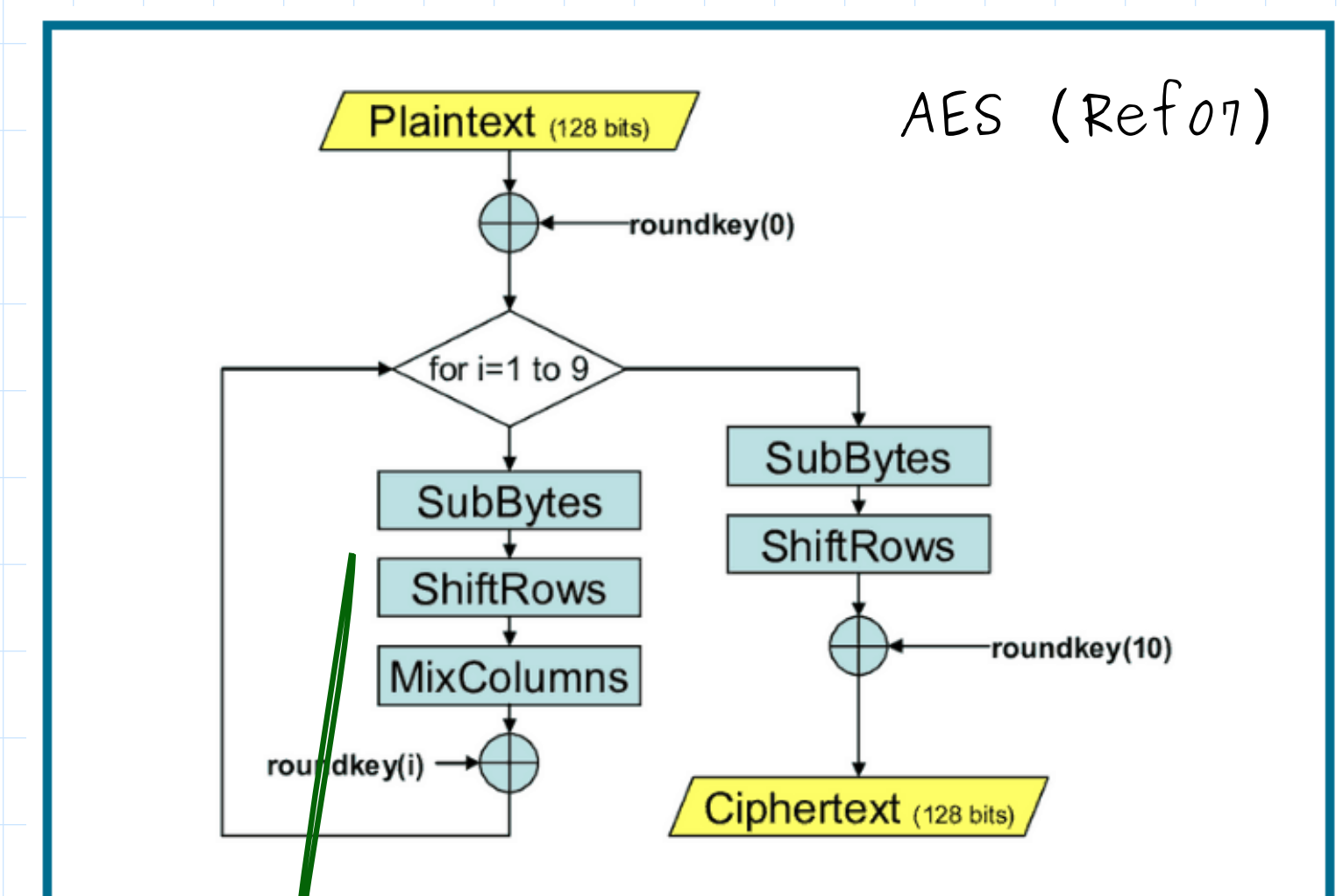
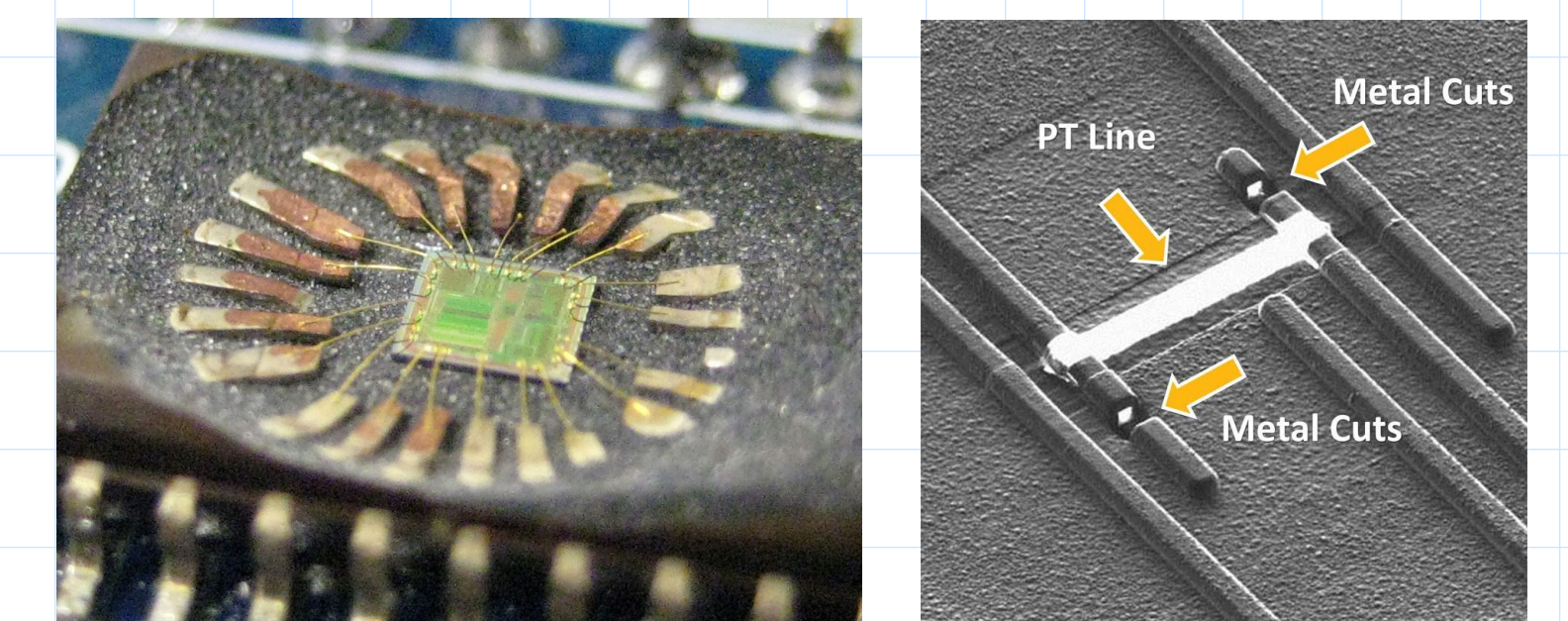
"Difference of means" (DoM)



✓ Correlation

✗ NO correlation

Level 6: IC decapping



AES (Ref07)

MCU, running AES encryption

Input

```
[0x34, 0xA0, ...]
[0x7D, 0x06, ...]
[0x0C, 0xF1, ...]
[0xB5, 0x82, ...]
```

Output (ADC data)

```
SubBytes[i] = sbox[ pt[i] ^ key[i] ]
```

16 x 256 times:
If key[0] == 0x7C, then...

